

보도시점 2025. 8. 28.(목) 11:00
(2025. 8. 28.(목) 석간)

배포 2025. 8. 28.(목) 06:00

개인정보위, 'SK텔레콤 개인정보 유출사고' 제재처분 의결

- ▷ 안전조치 의무 위반 및 유출 통지 위반으로 과징금 1,347억 9,100만 원, 과태료 960만 원 부과
- ▷ 3개월여간 집중조사 TF 운영 통해, “이동통신 관련 핵심 네트워크·시스템에 대한 관리 소홀로 2,300여만 명의 주요 디지털 개인정보(USIM 정보 등) 유출” 결론
 - ※ 인증키(Ki)도 유출되어 USIM 복제에 대한 사회적 우려가 컸으며, 조사 과정에서 “방화벽 설정 미흡으로 외부 침입 취약, 서버 계정정보(ID/PW) 관리 부실, 암호화 미실시, 악성프로그램 방지 소홀 등” 보호법 위반사항 확인
- ▷ 향후 개인정보보호 강화 위해 “CPO의 실질적 역할 보장, 위탁 관리·감독 철저 등도 포함해 3개월 내 재발방지 대책 수립·보고, 사고 발생 이동통신 네트워크·시스템에 대한 ISMS-P 인증 취득” 내용의 시정명령·개선권고 병행
- ▷ 다음 달 초 대규모 처리자의 개인정보보호·보안 관련 투자 확대 유도 위해 제도개선·인센티브 체계 개편 등을 담은 “개인정보 안전관리체계 강화 종합대책” 발표

개인정보보호위원회(위원장 고학수, 이하 ‘개인정보위’)는 8월 27일(수) 제18회 전체회의를 열고, 개인정보 보호 법규를 위반한 SK텔레콤(주)(이하 ‘SKT’)에 대해 과징금 1,347억 9,100만 원과 과태료 960만 원을 부과하고, 전반적인 시스템 점검 및 안전조치 강화, 전사적인 개인정보 거버넌스 체계 정비 등 재발 방지를 위한 시정조치(안)을 의결하였다.

1. 대응 경과

개인정보위는 지난 4월 22일 SKT가 비정상적 데이터 외부 전송 사실을 인지하고 유출 신고해움에 따라 조사에 착수하였다. 개인정보위는 사건의 중대성을 감안하여 신고 당일 한국인터넷진흥원(원장 이상중, 이하 ‘KISA’)과 함께 집중조사 태스크포스(이하 ‘TF’)를 구성하여 유출 관련 사실관계, 개인정보 보호법령 위반여부 등을 중점 조사하였다.

< 집중조사 TF 구성 및 조사방식 >

- ▷(구성) 개인정보위(조사관 4인, 사내변호사·회계사 3인), KISA(조사관 7인)
- ▷(조사방식) 현장조사, 서면조사 및 디지털 증거수집 등을 통해 SKT 주요 개인 정보처리시스템 대상 유출여부·규모, 보호법상 안전조치의무 준수 여부 집중 조사

2. 유출 관련 사실 관계 : 유출 내용 및 경위

TF의 조사 결과, SKT가 제공하는 이동통신 서비스의 핵심 역할을 하는 다수 시스템에 대한 해킹으로 LTE·5G 서비스 전체 이용자 23,244,649명* (알뜰폰 포함, 중복 제거)의 휴대전화번호, 가입자식별번호(IMSI), 유심 인증키(Ki, OPc) 등 25종의 정보가 유출된 것으로 확인되었다.

* 휴대전화번호·IMSI 기준 유출 규모는 약 2,696만 건으로 확인되나, 법인·공공회선, 다회선, 기타 회선 등을 제외한 이용자로 산정

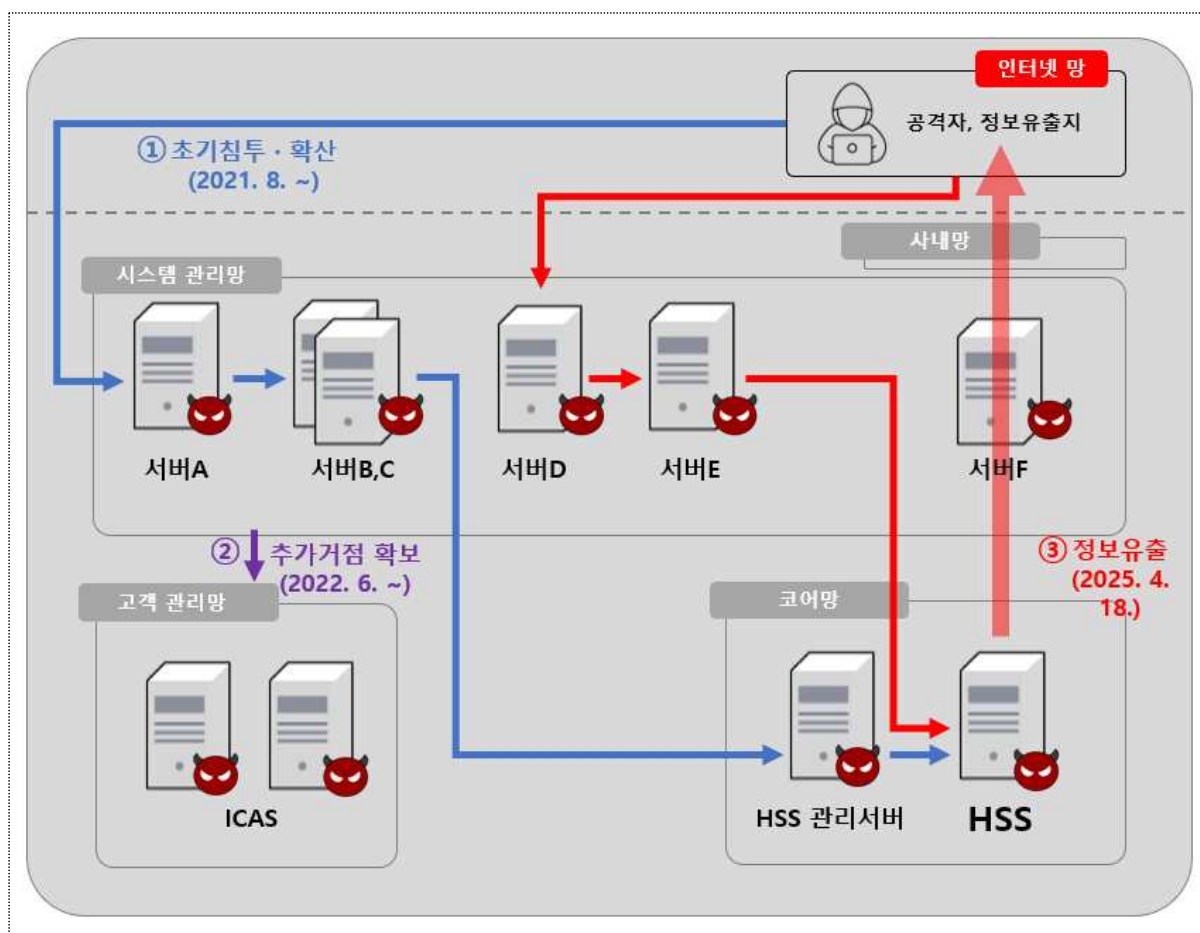
이번 사고는 개인을 식별·인증하고 연결하는 핵심 수단으로 휴대전화가 이용되고 각종 서비스의 본인 확인이 일상화된 상황에서, 이동통신 이용에 필요한 가입자식별번호(IMSI) 및 유심 인증키가 대규모로 유출됨에 따라 이동통신 서비스의 신뢰도가 저하되고, 사회적 불안감이 확산되는 등 국민 생활에 중대한 영향을 미쳤다.

조사결과, 해커는 ① '21. 8월 SKT 내부망에 최초침투하여 다수 서버에 악성 프로그램을 설치하였으며, ② '22. 6월 ICAS(통합고객인증시스템)* 내 악성 프로그램을 설치하여 추가 거점을 확보하였다. ③ 이후, '25. 4. 18. HSS (홈가입자서버)** DB에 저장된 이용자의 개인정보(9.82GB)를 외부로 유출하였다.

* **ICAS**(Intergrated Customer Authentication System) : Tworld 등 사내 서비스 및 사전 인가된 협력사 대상 SKT 가입자의 가입 상태, 정보 및 가입 상품 조회용 API 제공

** **HSS**(Home Subscriber Server) : 가입자의 이동통신망 접속을 위한 인증시스템

< 악성프로그램 감염 및 개인정보 유출 경위 >



- (코어망) 이동통신 서비스 이용자 및 단말기 인증관리, 통화 연결, 데이터 전송 등을 담당하는 핵심 네트워크
- (관리망) 장애 감지, 통화 및 서비스 품질 분석 등 이동통신 서비스 모니터링을 담당하는 운영·관리 네트워크
- (사내망) SKT, 협력사 임직원 등이 코어망·관리망 등에 접속하기 위한 사내망

3. 개인정보 보호법 위반 사항

SKT의 개인정보 처리·운영 실태와 개인정보 보호법 준수 여부를 조사한 결과, 이번 사고는 SKT의 기본적인 보안 조치 미비와 관리 소홀로 인해 발생한 것으로 확인되었다. 조사 과정에서 확인된 주요 위반 사항은 다음과 같다.

1) 안전조치 의무 위반

① 접근통제조치 소홀

SKT는 기본적인 접근통제조치 이행하지 않아 인터넷과 내부망 사이의 보안 운영 환경이 해커의 불법적인 침입에 매우 취약한 상태로 관리·운영되고 있었다.

SKT는 인터넷·관리·코어·사내망을 동일한 네트워크로 연결하여 운영하면서, 인터넷망(국내·외)에서 SKT 내부 관리망 서버로의 접근을 제한없이 허용하였다. 또한, 관리망 서버는 이번 유출 사고가 발생한 HSS와 상호접속이 불필요함에도 이를 허용하여, 해커가 인터넷망에서 HSS까지 접속하여 HSS DB 내 저장된 유심 정보 등을 외부로 전송할 수 있었다.

또한, SKT는 침입탐지 시스템의 이상행위 로그도 확인하지 않는 등 불법적인 유출 시도에 대한 탐지·대응 조치를 소홀히 하였다. 특히 SKT는 '22. 2월 해커가 HSS 서버에 접속한 사실을 확인했음에도, 비정상 통신 여부나 추가적인 악성프로그램 설치 여부, 접근통제 정책의 적절성 등을 점검하지 않아, 이번 유출 사고를 사전에 방지할 기회를 놓친 사실이 확인되었다.

② 접근권한 관리 소홀

한편, SKT는 다수 서버(약 2,365개)의 계정정보(ID/비밀번호 약 4,899개)가 저장된 파일을 관리망 서버에 암호 설정 등 제한 없이 저장·관리하고, HSS에서 비밀번호 입력 등 인증 절차 없이도 개인정보를 조회할 수 있도록 운영하였다. 이에 해커는 획득한 계정정보를 활용하여 관리망 서버에 접속, 악성프로그램을 설치하고 HSS DB 내 개인정보를 조회·추출할 수 있었다.

③ 보안 업데이트 미조치 등

이번 사고에서 해커가 악성프로그램(BPFDoor) 설치에 활용한 운영체제(OS) 보안 취약점(DirtyCow)은 '16. 10월에 이미 보안 경보가 발령되었고, 보안 패치가 공개된 사항이었다. SKT는 이를 인지하고 있었음에도, '16. 11월 이러한 보안 취약점을 가진 OS를 설치하였으며, '25.4.월 유출 당시까지도 보안 업데이트를 실시하지 않았다.

< DirtyCow 취약점 실행 악성파일 정보 >

```

printf(
    ..
    ..      (_____)
    ..      (0 0) ——— /
    ..      @ @ ——— /
    ..      / / ——— / %s
    ..      ^ ^      ^ ^
    ..
    enup,
    argu);

puts("DirtyCow root privilege escalation");
printf("Backing up %s to /tmp/bak\n",      );
asprintf(&ptr, "cp %s /tmp/bak",      );
system(ptr);
f = open(      , 0);
fstat(f, &st);
map = mmap(0LL, st.st_size + 8, 1, 2, f, 0LL);
printf("mmap %x\n\n", map);
pid = fork();
if ( pid )

```

또한, 최소 '20년부터 각종 상용 백신 프로그램은 해당 취약점의 실행을 탐지하고 있었으나, SKT는 '25. 4월까지 이를 설치하지 않았을 뿐만 아니라 백신 미설치를 대체하는 보안 조치마저도 소홀히 하여 결과적으로 이번 유출 사고를 막지 못하였다.

< 백신 탐지 결과(최소 '20년부터 탐지) >

④ 유심 인증키를 암호화하지 않고 평문으로 저장

SKT는 가입자 인증과 이동통신 서비스 제공에 필수적으로 사용되는 인증 정보인 유심 인증키(Ki) 26,144,363건을 암호화하지 않고, 평문으로 HSS DB 등에 저장하였다. 이에 해커는 유심 복제에 사용될 수 있는 유심 인증키를 원본 그대로 확보할 수 있었다.

특히 SKT는 '22년경 언론에서 유심 복제 등의 이슈가 제기됨에 따라 암호화 조치를 검토하면서, 타 통신사가 유심 인증키(Ki)를 암호화하여 저장하고 있음을 확인하였음에도(LGU+('11년~), KT('14년~)), 이를 조치하지 않아 유출 피해를 예방하지 못한 사실이 확인되었다.

※ 이 외 내부 관리계획 수립·시행 및 점검 소홀, 접속기록 미보관 등 안전조치의무를 준수하지 않았고, SKT가 자체 마련한 내부규정도 다수 위반한 것으로 확인

2) 개인정보 보호책임자 지정 및 업무 수행 소홀 등

SKT는 IT 영역과 통신 인프라 영역 모두에서 이동통신 서비스 제공을 위한 개인정보를 처리함에도, 개인정보 보호책임자(Chief Privacy Officer, 이하 'CPO')의 역할은 IT 영역(Tworld 등 웹·앱 서비스)에 한정되도록 구성·운영하였다.

이에 이번 유출 사고가 발생한 인프라 영역은 CPO가 개인정보 처리 실태조차 파악하지 못하는 등 CPO의 관리·감독이 사실상 이루어지지 않은 것으로 확인되었다.

3) 개인정보 유출통지 지연

SKT는 '25. 4. 19.경 HSS DB에 저장된 데이터가 외부로 전송된 사실을 확인하여 개인정보 유출 사실을 인지하였음에도, 법령에서 정한 72시간 내 유출된 이용자를 대상으로 유출 사실을 통지하지 않아 이로 인한 사회적 혼란이 가중되었다.

이에 개인정보위는 즉시 유출통지를 진행할 것을 긴급 의결(5.2.)하였으나, SKT는 5.9. 유출 “가능성”에 대하여 통지를 실시하였으며, 7.28.에서야 유출 “확정” 통지를 실시하는 등 개인정보 유출 시 이용자 피해 예방을 위해 보호법에서 규정한 최소한의 의무조차 이행하지 않았다.

4. 처분 내용 및 의의

개인정보위는 SKT가 국내 1위 이동통신사업자로서 안전조치의무를 소홀히 하여 유심정보를 비롯한 개인정보가 유출된 행위에 대해 과징금 1,347억 9,100만 원을 부과하는 한편, 정보 주체에 대한 유출 통지를 지연하여 신속한 피해 확산방지를 소홀히 한 행위에 대해 과태료 960만 원을 부과하기로 결정하였다.

아울러, 유출 사고 재발 방지를 위해 이동통신 서비스 전반의 개인정보 처리 현황을 면밀히 파악하여 안전조치를 강화하고, 개인정보 보호책임자(CPO)가 회사 전반의 개인정보 처리 업무를 총괄할 수 있도록 거버넌스 체계를 정비할 것을 시정명령하였다.

또한, 현재 일부 고객관리시스템(T World 등)에 대해서만 획득한 개인정보 보호관리체계(ISMS-P) 인증 범위를 이동통신 네트워크 시스템으로 확대하여 회사 시스템 전반의 개인정보 안전성 확보조치 수준을 제고하도록 개선 권고하였다.

이번 처분에 앞서 개인정보위는 조사 결과 및 처분 방향에 대해 위원들간 충실한 논의 및 의견수렴을 위해 총 네 차례의 사전 검토회의를 거쳤고, 전체 회의(8.27) 시 사업자가 출석하여 의견 개진 및 질의·응답 등을 거친 후 최종 처분안을 확정하였다.

이번 조사·처분은 단순히 특정 기업에 대한 제재를 넘어, 우리 사회 전반에 개인정보 보호의 중요성을 다시 한번 환기시키는 계기가 될 것으로 보고 있다. 특히 기업이 이용자 개인정보를 보호할 책임을 다하지 못해 국민이 입은 불안과

피해에 대해 국가가 엄정하게 대응함으로써 다른 기업들에게도 개인정보 관리체계 강화 및 예방적 보호 조치 마련에 대한 경각심을 줄 것으로 기대된다.

아울러 개인정보위는 유사사태가 발생하지 않도록 대규모 개인정보 처리자에 대한 관리·감독을 더욱 강화하고, 개인정보 안전관리 체계 강화방안을 마련하여 9월 초 발표할 예정이다.

고학수 개인정보위 위원장은 “이번 사건을 계기로 대규모 개인정보를 보유·처리하는 사업자들이 관련 예산과 인력의 투입을 단순한 비용 지출이 아닌 필수적인 투자로 인식하길 바라며, 나아가 데이터 경제시대 CPO와 전담조직이 기업경영에서 차지하는 역할과 중요성을 제고하여 개인정보 보호 체계가 한 단계 강화되는 계기가 되길 바란다.”라고 말했다.

< 총괄 >	개인정보보호위원회 조사2과	책임자	과 장	이정은 (02-2100-3121)
		담당자	조사관	허재형 (02-2100-3129)
		담당자	조사관	채 리 (02-2100-3159)
< 분쟁조정 >	분쟁조정과	책임자	과 장	이훈식 (02-2100-3141)
		담당자	서기관	김영일 (02-2100-3146)
< 안전대책 >	신기술개인정보과	책임자	과 장	고낙준 (02-2100-3061)
		담당자	서기관	정종일 (02-2100-3066)
< 공동 >	한국인터넷진흥원 개인정보조사단	책임자	단 장	차윤호 (061-820-2800)
		담당자	팀 장	조형진 (061-820-2850)



- ① (초기침투) '21. 8. 6. 해커는 인터넷과 연결된 SKT 관리망 서버에 접근하여 원격제어 프로그램을 설치하였고, 원격으로 접속한 관리망에서 평문으로 저장된 계정정보*를 획득

* 최소 2,365대 서버, 4,899개 계정정보(ID/PW) 평문 저장

- 해커는 획득한 계정을 이용하여 코어망 서버에 접속하였고, 운영 OS의 취약점(DirtyCow*)을 활용하여 관리자 권한을 획득한 뒤 HSS DB에 악성프로그램인 BPFDoor**를 설치

* 리눅스 OS의 일반계정을 이용해 관리자 권한(root)을 획득할 수 있는 보안 취약점

** 포트를 열지 않고도 해커의 명령을 받아 원격으로 시스템을 제어하는 악성코드

- ② (추가 거점확보) '22. 6. 15 해커는 ICAS 내 2대 서버에 접근하여 초기침투와 동일한 OS취약점을 이용해 관리자 권한을 획득한 뒤 서버에 BPFDoor 등 악성프로그램 감염

- ③ (개인정보 유출) '25. 4. 18. 해커는 이미 설치된 악성프로그램을 이용해 외부에서 HSS DB에 명령어를 입력하였고, HSS DB에 저장된 이용자 개인정보를 조회, 파일로 추출한 뒤 압축하여 외부로 유출

- 감염된 ICAS 서버에는 이용자의 이름, 생년월일, 주소, 이메일, 단말기 식별번호(IMEI) 등이 임시 저장되어 있으나, 해당 서버의 방화벽 로그 기록을 4개월만 보관하여, '24. 12월 ~ '25. 4월간은 외부로 유출된 정황은 없는 것으로 확인
- 다만, 그 이전 기간('22.6~'24.12)에 대해서는 유출여부를 확인할 수 없었음

1. 집중조사 TF의 구성·운영 관련

- 국내 1위 통신사에서 유심정보 등이 유출된 사건의 중대성을 감안하여, 신고 당일(4.22.)부터 집중조사 TF를 구성·운영
 - 개인정보위 및 KISA 조사관 10인 이상이 전담으로 약 3개월 간 현장에 상주하며, 조사를 밀도있게 진행
 - ※ (개인정보위) 조사관(조사 경력자) 4명, 송무팀(변호사·회계사) 3명, (KISA) 조사관(기술지원) 7명
- 이외에도, 매출액 분석 및 법률적·기술적 사항 검토에 개인정보위 변호사, 회계사 및 외부 전문가 다수 투입

2. 유출된 정보(휴대전화번호, IMSI, 유심 인증키)가 개인정보에 해당하는지?

- 휴대전화번호는 일반적으로 특정 개인에게 귀속되는 정보로, 모바일 시대 개인을 식별하고 연결하는 핵심수단으로 이용되는 중요한 개인정보에 해당함
 - IMSI 및 유심 인증키는 특정 개인을 식별하기 위하여 SKT가 이용자 단말에 부여하는 고유의 값으로, SKT는 해당 정보를 가입자 인증 및 서비스 권한 확인 등에 활용하고 있으며,
 - SKT는 유출된 정보 외에 성명, 주소, 서비스 이용기록 등의 이용자 개인정보를 함께 보유·관리하여 이를 언제든지 쉽게 서로 결합(집합물 형태, 패키지)하여 개인을 알아볼 수 있음

3. 유심 인증키가 보호법상 암호화 대상인 인증정보 해당 여부

- 유심 인증키는 통신 네트워크 연결 시 단말기 소유자의 정당성을 인증하는데 사용되어, 보호법상 ‘인증정보’로 판단
- SKT 이용자가 이동통신망 접속을 요청할 때, HSS 등의 시스템과 이용자 단말에 각각 저장된 IMSI를 통해 인증을 요청한 가입자를 식별하고 유심 인증키(Ki)로 인증값을 비교하는 방법으로 상호 인증하며,
- 인증이 완료된 단말을 소유한 이용자에게만 피심인의 이동통신 서비스를 제공하고 있으므로, “개인정보처리시스템에 접속을 요청하는 자의 신원을 검증하는데 사용되는 정보”로 기타 암호화 대상 인증정보에 해당함

※ KT, LGU+는 국제 권고에 따라 각각 '14년 및 '11년부터 유심 인증키를 암호화 저장

4. SKT의 유출 통지 지연 관련

- SKT는 ‘25. 4. 19. 23:40 개인정보 유출 사실을 인지하고, 4.25.경에는 유출된 정보의 규모 등을 확인하였음에도,
- 민관합동조사단(과기정통부)의 조사가 진행 중인 이유로 5. 9.에서야 유출 “가능성” 통지를 실시하고, 민관합동 조사단의 조사 결과 발표 (7.4.) 이후 7. 28. 개인정보 유출통지를 진행하였음
- 이에 개인정보위는 SKT가 **정당한 사유 없이 유출 통지를 지연하여**, 정보주체의 2차 피해 예방을 어렵게 한 것으로 보아, 통지 의무를 위반한 것으로 판단함

※ 개인정보보호법상 개인정보 유출 사실을 알게 된 때로부터 72시간 내 유출 통지 의무

※ 국회에서 관련 법 개정 논의가 있어, 위원회도 적극 참여중

5. 과징금 산정 관련

- 과징금 산정 기준이 되는 매출액은 SKT의 전체 이동통신서비스 매출액을 기준으로 산정

※ SKT 전체 매출액에서 위반행위와 관련없는 매출액 제외

- 다수의 안전조치의무 위반 사항이 유출사고의 직접적 원인이 된 점, 가입자 인증에 필요한 핵심 정보(유심 인증키 등)가 유출된 점, 약 2,300만 명의 대규모 개인정보가 유출된 점 등을 고려하여, “매우 중대한 위반행위”로 판단
- 또한, SKT의 위반행위 기간이 장기간(2년 이상) 지속된 점 등을 고려하여 일부 가중하였고, 본 건 유출사고 관련 위반행위를 시정한 점, 이용자의 피해 회복을 위해 노력한 점, 기타 개인정보 보호 노력 등을 고려하여 일부 감경 적용함

6. 이번 처분에서의 시정명령·개선권고 내용

- 위원회는 SKT가 국민 생활에 밀접한 이동통신 서비스를 제공하는 기간통신사업자로서 개인정보보호 강화 및 유출 사고 재발 방지를 위해 다음 사항들을 시정·개선하도록 함
- CPO의 실질적 역할 보장*, 위·수탁 관리·감독 철저, 개인정보 보호 관련 사회적 책임 강화 등을 포함해 위원회와 협의하여 재발방지 대책 수립·보고하도록 시정명령 및 사고 발생 이동통신 네트워크·시스템에 대한 ISMS-P 인증을 취득하도록 개선권고

* 예시 : 전사 관할, 이사회에 정기 보고 등

7. 개인정보 안전관리 체계 강화를 위한 대책

- 개인정보위는 유사사례가 발생하지 않도록 대규모 개인정보 처리자에 대한 관리·감독을 더욱 강화하고, 투자 확대 유도에 초점을 맞춰 개인정보 안전관리 체계 강화방안을 마련하여 9월 초 발표할 예정

8. 이번 사고 관련 개인정보위에 접수된 분쟁조정 신청 현황과 향후 일정

- 이번 사건 관련 SKT를 상대로 개인정보위에 접수된 집단 분쟁조정 신청은 3건으로 약 2,025여명이 참여하고 있으며, 개인분쟁조정 신청은 약 610여 건(8.27.기준)이 접수됨
- 다만, 조사 진행 중인 사안으로 분쟁조정절차가 정지된 상태였으나, 처분 절차가 완료되면 중단된 절차를 개시할 예정임